LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

SMB Threat Landscape: Fake AI Tools and Phishing Lures

Threat Report

Classification	TLP:CLEAR
Published	2026-08-25
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

Published: 2026-08-25 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

SMB Threat Landscape: Fake AI Tools and Phishing Lures

1. Executive Summary

Securelist reporting on 2026 SMB threats emphasizes fake AI tools, phishing, and software lures. The defender priority is user-facing control coverage: download restrictions, browser/email telemetry, and rapid credential reset.

This daily automation product emphasizes defender actionability over attribution certainty. Where reporting is trend-level rather than incident-specific, confidence is stated at the behavior and sector-risk level rather than as a claim of a specific intrusion against a named victim.

2. Intelligence Requirements

Question	Current Answer	Confidence
What activity should defenders prioritize?	Threat actors package malware and unwanted software as AI, collaboration, and office tools to reach small and midsize organizations.	Medium-High
Which environments are most exposed?	SMBs, distributed teams, MSP-supported clients, and organizations adopting unsanctioned AI tools.	Medium
What can be hunted today?	Identity anomalies, suspicious scripting, data staging, and unusual outbound traffic tied to the reported behavior.	Medium

3. Source Review & Confidence

Source	Contribution	Confidence
Securelist SMB Threat Report 2026	Primary SMB threat landscape source	High
Securelist malware report Q2 2026	Supporting malware/IoT trend context	Medium
Proofpoint adversarial prompt injection notes	Supporting context on adversarial use of AI-themed operations	Medium

Sources were selected for public availability and defensive relevance. This report avoids naming victims or IOCs that were not present in the cited material.

4. Threat Activity Overview

Threat actors package malware and unwanted software as AI, collaboration, and office tools to reach small and midsize organizations.

5. Affected Sectors and Exposure

SMBs, distributed teams, MSP-supported clients, and organizations adopting unsanctioned AI tools.

Exposure Pattern	Why It Matters
Cloud identity and SSO	Credential theft, token abuse, and OAuth/device-flow misuse can bypass perimeter assumptions.
Public webmail / collaboration systems	Exploit and phishing paths often start at mail, collaboration, or admin portals.

Supplier and managed-service access	Third-party pathways can reach internal systems without direct targeting.
Unmonitored data staging	Extortion crews frequently stage data before public impact is visible.

6. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	Phishing, exploit public-facing application, or valid-account abuse	Common pathway across the source reporting.
Execution	Command/scripting or living-off-the-land administration	Defenders should prioritize child-process and admin-tool anomaly detection.
Credential Access	Token/session theft or credential harvesting	Identity-centric reporting and extortion operations emphasize credential abuse.
Exfiltration / Impact	Data staging, extortion, ransomware, or operational disruption	Trend reporting highlights monetization through theft and service disruption.

7. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
No unique hard IOCs published in this synthesized daily report	Source limitation	Hunt behavior rather than block fabricated indicators.
Recently created domains impersonating trusted services	Infrastructure pattern	Feed phishing-domain monitoring and proxy review.
Unusual OAuth grants, device-code flows, or new mailbox rules	Identity indicators	Detect account takeover and persistence.

8. Detection Engineering

This section provides portable behavior-first analytics that defenders can adapt to Microsoft Defender, Sentinel, Splunk, or EDR platforms.

8.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
New or rare OAuth grants / device flow sign-ins	Entra ID / IdP logs	Detect identity-centric phishing and token abuse.
Scripting launched by web, mail, browser, or admin tooling	EDR process telemetry	Surface post-exploitation and malware staging.
Large archive creation followed by external transfer	File/process/network telemetry	Detect data staging before extortion or ransomware.

8.2. Sigma / Detection Content

```
title: Suspicious Identity Or Web-Initiated Intrusion Activity - SMB Threat Landscape: Fake AI Tools and Phishing Lures
status: experimental
```

```
logsource:
  product: windows
  category: process_creation
detection:
  parent_web_or_mail:
    ParentImage|contains:
      - 'w3wp.exe'
      - 'httpd'
      - 'nginx'
      - 'outlook.exe'
      - 'chrome.exe'
      - 'msedge.exe'
  child_lolbin:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
      - '\rundll32.exe'
      - '\mshta.exe'
      - '\wscript.exe'
  condition: parent_web_or_mail and child_lolbin
level: high
```

8.3. Hunt Query

```
SigninLogs
| where TimeGenerated > ago(14d)
| where ResultType == 0
| where AuthenticationProtocol has_any ("deviceCode", "oauth", "ropc") or AppDisplayName has_any
("Office", "Azure", "Graph")
| summarize FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), Apps=make_set(AppDisplayName,
20), IPs=make_set(IPAddress, 20) by UserPrincipalName, AuthenticationProtocol
| where array_length(IPs) > 3 or array_length(Apps) > 5
```

9. Threat Hunting

9.1. Hunt Hypothesis

If this activity is present, analysts should observe unusual identity grants or sign-ins before endpoint execution, followed by data discovery, archive creation, or external transfer.

9.2. Hunt Query

```
DeviceFileEvents
| where Timestamp > ago(14d)
| where FileName endswith ".zip" or FileName endswith ".7z" or FileName endswith ".rar"
| summarize Archives=count(), Paths=make_set(FolderPath, 20) by DeviceName,
InitiatingProcessAccountName, bin(Timestamp, 1d)
| where Archives > 10
```

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName has_any ("powershell.exe", "rclone.exe", "curl.exe", "wget.exe",
"python.exe", "browser.exe")
| summarize Connections=count(), RemoteUrls=make_set(RemoteUrl, 25) by DeviceName,
InitiatingProcessAccountName, InitiatingProcessFileName
| where Connections > 25
```

10. Risk Assessment

Dimension	Assessment	Rationale
Likelihood	Medium to High	The activity aligns with current public reporting and common attacker tradecraft.
Impact	Medium to High	Identity compromise, data theft, or operational disruption can create material

		business impact.
Detection Difficulty	Medium	Behavior-based detections are feasible but require IdP, endpoint, and network telemetry correlation.

11. Recommended Actions

Priority	Owner	Action
Critical	Identity / IAM	Enforce phishing-resistant MFA for administrators and high-risk users.
High	SOC	Run included KQL hunts and review unusual OAuth/device-flow events.
High	Endpoint Engineering	Alert on suspicious interpreter launches from browsers, mail clients, and web services.
Medium	Business Continuity	Validate response runbooks for data extortion, service disruption, and supplier outage scenarios.

12. References

- [1] Securelist SMB Threat Report 2026: https://securelist.com/smb-threat-report-2026/120357/
- [2] Securelist malware report Q2 2026: https://securelist.com/malware-report-q2-2026-pc-iot-statistics/120960/
- [3] Proofpoint adversarial prompt injection notes: https://www.proofpoint.com/us/blog/threat-insight/notes-underground-adversarial-prompt-injection